

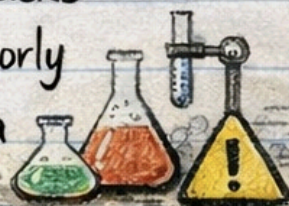
What is Mutillidae?

Day 18

Mutillidae is a deliberately vulnerable web application used for learning web application security.



It helps simulate real-world attacks that are commonly found in poorly maintained websites, all inside a safe lab environment.



Mutillidae Exists, Most real attacks don't happen on advanced systems.

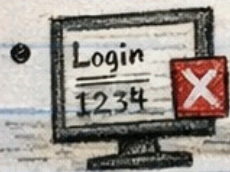
They happen on:



Outdated Websites



Poorly Configured Servers

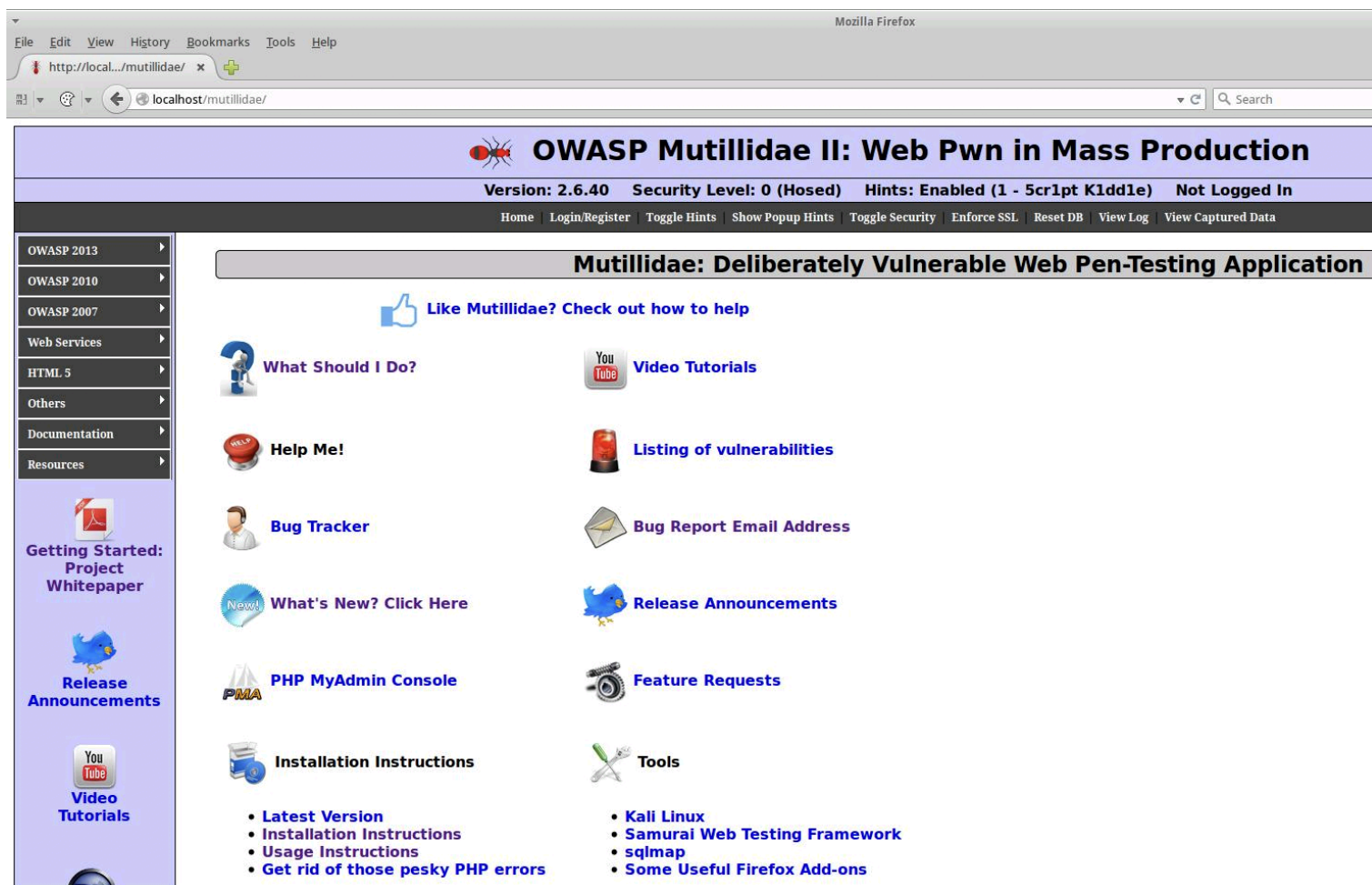


Applications with Weak Validation



Mutillidae is built to replicate these exact mistakes.





Version: 2.6.40

Security Level: 0 (Hosed)

Hints: Enabled (1 - 5cr1pt K1dd1e)

Not Logged In

[Home](#) | [Login/Register](#) | [Toggle Hints](#) | [Show Popup Hints](#) | [Toggle Security](#) | [Enforce SSL](#) | [Reset DB](#) | [View Log](#) | [View Captured Data](#)

OWASP 2013

OWASP 2010

OWASP 2007

Web Services

HTML 5

Others

Documentation

Resources



[Getting Started:](#)

Login



[Back](#)



[Help Me!](#)



[Hints and Videos](#)

Please sign-in

Username

Password

Login

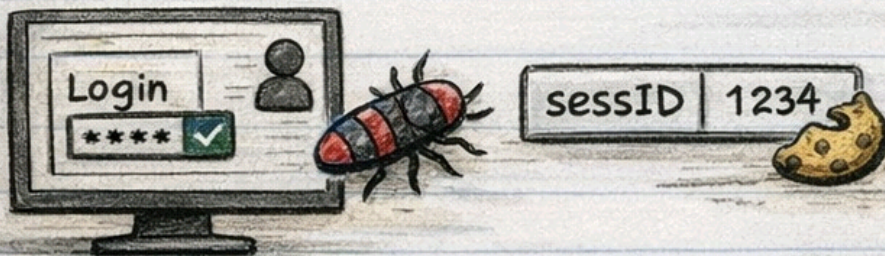
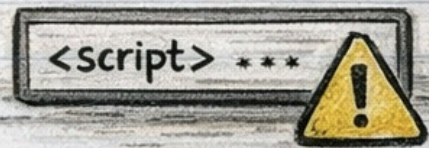
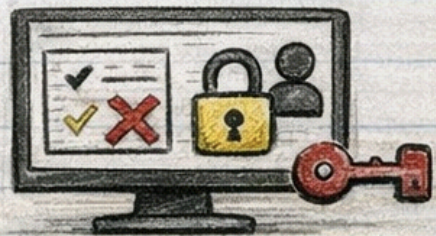
Dont have an account? [Please register here](#)

How Mutillidae Works



Mutillidae intentionally includes:

- ☒ Weak authentication
- ☒ Broken authorization
- ☒ Insecure input handling
- ☒ Poor session management



- ☒ Improper error handling



These flaws allow attackers to exploit the application just like in real-world scenarios.



1. Weak Authentzation & Broken Authorization (Mutillidade)

Weak Authenitaton



- Login pages vulnerable to SQL injection



- Authentcation bypass using crafted inputs

Real-world similarity:



- Poor password handling and missing input validation

Broken Authotization



- Direct access to admin or restricted pages



- Role checks missing or improperly enforced

Real-world similarity:



- Users accessing data or functions they should never see

Insecure Input Handling

What you'll see in Mutillidae:

- ✓ Input fields accepting scripts or SQL commands
- ✓ No sanitization or validation

Real-world similarity:

- ✓ Common cause of SQL Injection and XSS attacks.

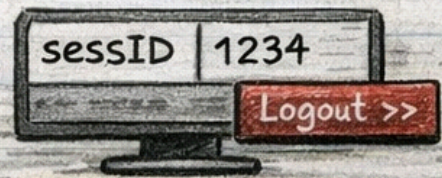


Poor Session Management

- ✓ Predictable session IDs
- ✓ Sessions not invalidated after logout

Real-world similarity:

- ✓ Leads to session hijacking and account takeover.



Improper Error Handling

- ✓ Detailed SQL errors
- ✓ Stack traces exposed to users



Real-world similarity:

- ✓ Attackers gain database structure and backend logic info.

